

AWS Cloud Security Configuration Assessment Report

Asia Pacific (Mumbai) — ap-south-1

Field	Detail
Assessment Type	AWS Security Configuration Assessment
Region	Asia Pacific (Mumbai) — ap-south-1
Assessment Date	24-25 August 2026
Environment	AWS Security Lab
Primary S3 Bucket	aws-security-lab-1470
Overall Risk Rating	Moderate — Needs Improvement

Prepared by
Ishaan Malhotra

Prepared as a configuration-review assessment. This report is not a penetration test.

1. Executive Summary

A security configuration assessment was performed against the AWS lab environment to identify common cloud-security risks across Identity & Access Management (IAM), S3 security, network configuration, encryption and key management, logging and monitoring, serverless services, database and container services, secret management, and external access.

Overall Assessment

Security posture: Moderate / Needs Improvement

The environment has strong baseline controls around S3 public-access protection, S3 object ownership, and external-access exposure — the IAM Access Analyzer scan returned zero external-access findings. However, several security-hardening controls are disabled, unconfigured, or missing: S3 versioning, S3 server access logging, a dedicated CloudTrail trail, MFA on the root user, and CloudWatch alarming/monitoring.

The most significant gap identified is that the AWS root user does not have multi-factor authentication (MFA) enabled, and all activity observed in Event History during the assessment window was performed by the root user rather than a named IAM identity — no IAM users, groups, or policies exist in the account. This is a materially higher-risk finding than anything in the original draft of this report and is addressed in Section 4.

No critical externally accessible finding was identified through the IAM Access Analyzer scan, and the single EC2 instance deployed during testing was found to have no open inbound rules by default; SSH access was subsequently restricted to a single administrative IP address using key-based authentication only.

2. Methodology

The assessment followed a configuration-review methodology rather than exploitation.

Assessment process

- Identify AWS resources and services.
- Review security configurations.
- Check public / external access.
- Review encryption settings.
- Review logging and monitoring.
- Review network architecture.
- Identify missing security controls.
- Classify findings by risk.
- Provide remediation recommendations.

Important: This assessment evaluates configuration and security posture. It does not represent a penetration test.

3. Identity & Access Management (IAM)

This section was expanded from the original draft, which covered only the IAM Access Analyzer output. Evidence collected from the IAM dashboard and CloudTrail Event History shows a materially incomplete IAM setup.

3.1 IAM Dashboard

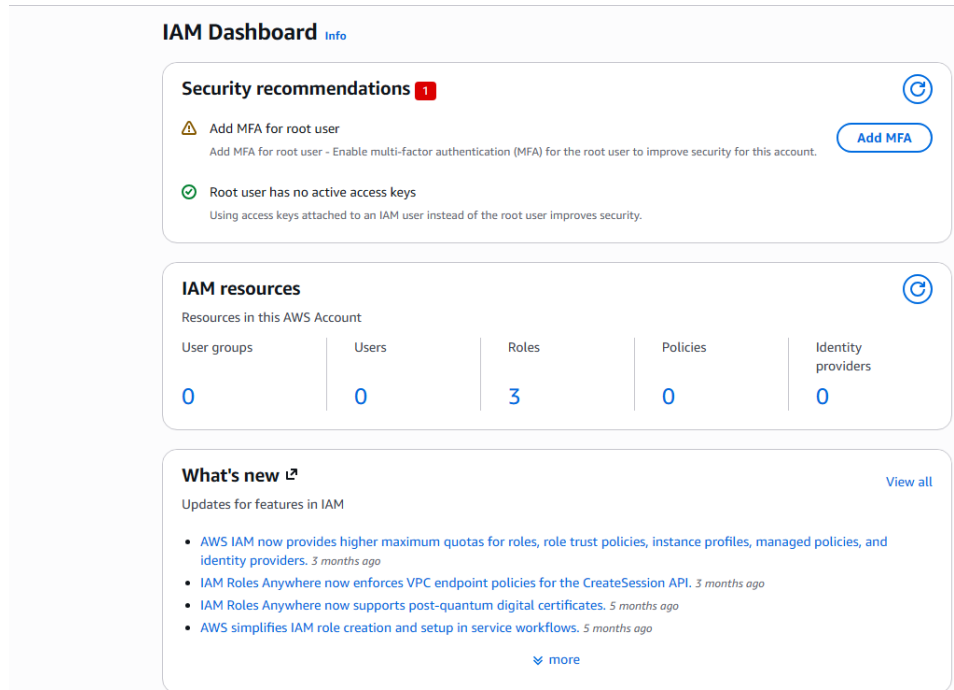


Figure 1 — IAM Dashboard: MFA not enabled for the root user; root user has no active access keys; 0 users, 0 groups, 0 policies, 3 roles.

Finding: Root User Has No MFA Enabled

Severity: High

The IAM security recommendations panel flags that multi-factor authentication is not enabled for the root user. The root user has unrestricted control over the AWS account, including billing, IAM, and the ability to delete any resource or close the account. A compromised password with no MFA is a single point of failure for the entire environment.

Recommendation: Enable MFA (hardware key or virtual authenticator) on the root user immediately, and avoid using the root user for routine tasks going forward.

Finding: No IAM Users Configured — Root Used for All Operations

Severity: Medium

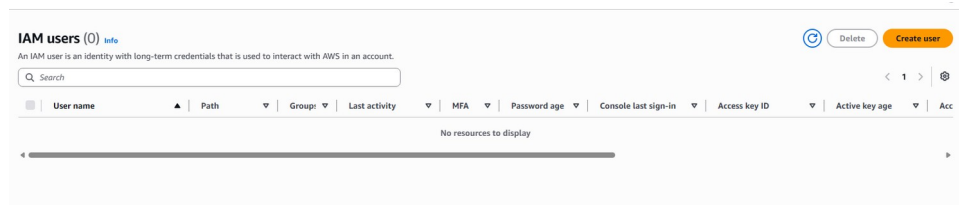


Figure 2 — IAM Users: 0 users configured in the account.

CloudTrail Event History confirms that every logged action during the assessment window — including S3 bucket creation, encryption changes, EC2 instance connect requests, and security group modifications — was performed by the root user. No IAM users, groups, or customer-managed policies exist (3 IAM roles are present, likely AWS service-linked roles).

Event name	Event time	User name	Event source	Resource type	Resource name
PutBucketEncryption	August 25, 2026, 01:34:30 (UTC...)	root	s3.amazonaws.com	AWS::S3::Bucket	aws-security-lab-1470
CreateBucket	August 25, 2026, 01:34:29 (UTC...)	root	s3.amazonaws.com	AWS::S3::Bucket	aws-security-lab-1470
CreateBucket	August 25, 2026, 01:34:06 (UTC...)	root	s3.amazonaws.com	AWS::S3::Bucket	aws-security-lab
SendSSHPublicKey	August 24, 2026, 21:20:56 (UTC...)	root	ec2-instance-connect.amazonaws.com	AWS::EC2::Instance	i-0686d54b09b6f62a
ModifySecurityGroup...	August 24, 2026, 21:20:49 (UTC...)	root	ec2.amazonaws.com	AWS::EC2::SecurityGroup	sg-073d551a298261aa6
SendSSHPublicKey	August 24, 2026, 21:19:02 (UTC...)	root	ec2-instance-connect.amazonaws.com	AWS::EC2::Instance	i-0686d54b09b6f62a
AuthorizeSecurityGro...	August 24, 2026, 21:18:31 (UTC...)	root	ec2.amazonaws.com	AWS::EC2::SecurityGroup	sg-073d551a298261aa6
SendSSHPublicKey	August 24, 2026, 21:12:29 (UTC...)	root	ec2-instance-connect.amazonaws.com	AWS::EC2::Instance	i-0686d54b09b6f62a
SendSSHPublicKey	August 24, 2026, 21:11:29 (UTC...)	root	ec2-instance-connect.amazonaws.com	AWS::EC2::Instance	i-0686d54b09b6f62a
SendSSHPublicKey	August 24, 2026, 21:08:25 (UTC...)	root	ec2-instance-connect.amazonaws.com	AWS::EC2::Instance	i-0686d54b09b6f62a

Figure 3 — CloudTrail Event History: every recorded event is attributed to the root user.

AWS best practice is to avoid using the root user for day-to-day operations. Operating exclusively as root removes the ability to apply least-privilege permissions, attribute actions to individual operators, or revoke access without rotating root credentials.

Recommendation: Create named IAM users or federated roles with least-privilege policies for daily administrative work, and reserve the root user strictly for the small set of tasks that require it.

Positive control: the root user has no active access keys, which avoids long-lived root credentials being embedded in scripts or tooling.

4. S3 Security Assessment

Bucket: aws-security-lab-1470 | ARN: arn:aws:s3:::aws-security-lab-1470

4.1 Configuration Summary

Control	Status
Block Public Access	✓ Enabled
Object Ownership	✓ Bucket owner enforced
ACLs	✓ Disabled
Bucket Policy	✓ None configured
CORS	✓ None configured
Default Encryption	✓ SSE-S3

Control	Status
Static Website Hosting	✔ Disabled
Requester Pays	✔ Disabled
Object Lock	⚠ Disabled
Versioning	⚠ Disabled
Server Access Logging	⚠ Disabled
Event Notifications	Not configured

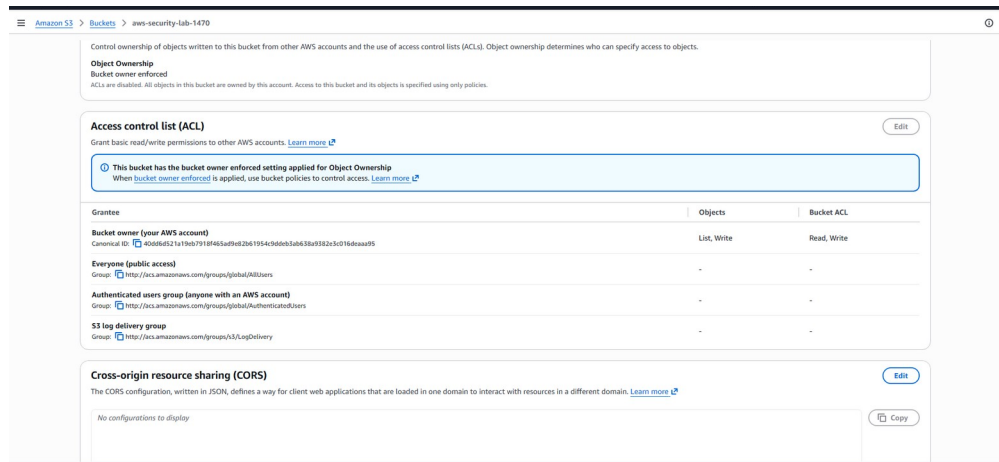


Figure 4 — S3 Object Ownership (bucket owner enforced) and ACL grantees.

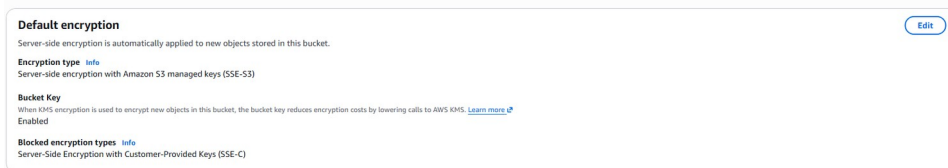


Figure 5 — Default encryption: SSE-S3 with bucket keys enabled.

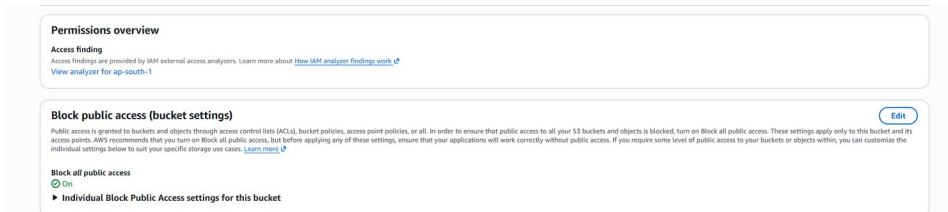


Figure 6 — Block Public Access: all settings enabled.

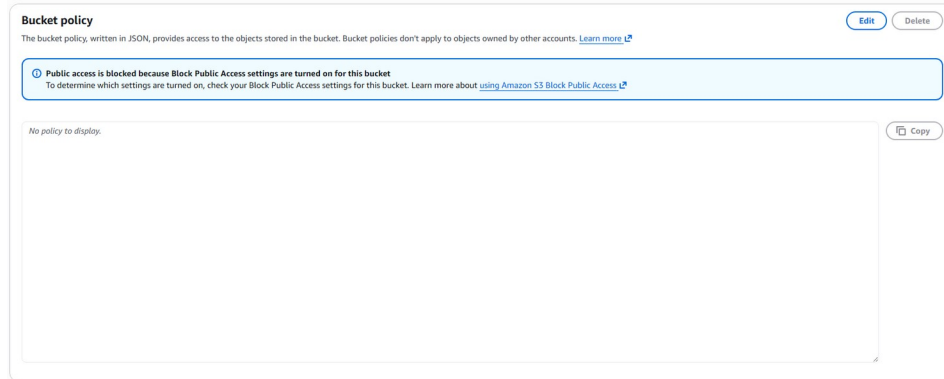


Figure 7 — No bucket policy configured; access is fully governed by Block Public Access.

Finding: S3 Versioning Disabled

Severity: Medium

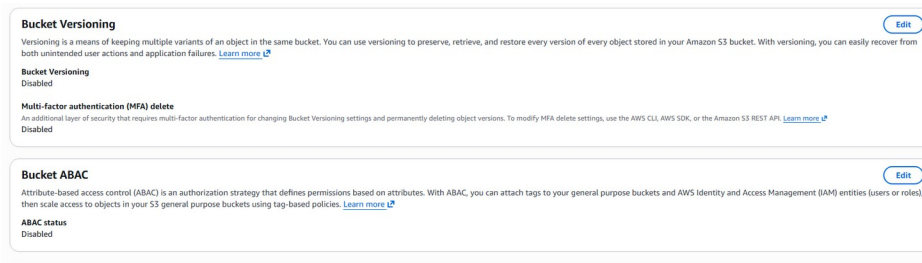


Figure 8 — Bucket Versioning: Disabled; MFA delete: Disabled.

Versioning can help recover objects after accidental deletion, modification, or certain ransomware-style incidents.

Recommendation: Enable S3 Versioning for important production or security-sensitive buckets.

Finding: S3 Object Lock Disabled

Severity: Low / Medium

Object Lock provides WORM-style protection against modification or deletion when appropriately configured.

Recommendation: Consider Object Lock for critical backups, logs, compliance records, and other data requiring immutability.

Finding: S3 Server Access Logging Disabled

Severity: Medium

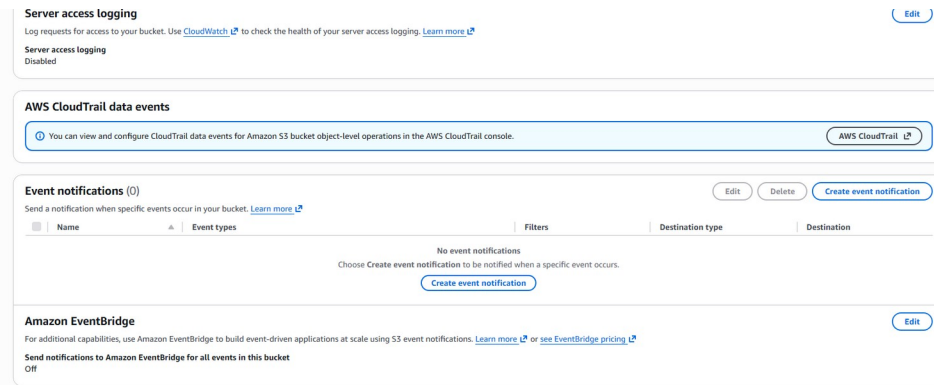


Figure 9 — Server access logging disabled; no S3 event notifications configured.

Server access logging provides additional visibility into requests made against the bucket.

Recommendation: Enable appropriate access logging, or ensure equivalent object-level monitoring is provided through CloudTrail data events.

Positive Finding: Public Access Protection

Severity: Informational / Positive Control

Block all public access is ON. The bucket also uses Bucket Owner Enforced object ownership, meaning ACL-based access control is disabled. This significantly reduces the risk of accidental public S3 exposure.

5. AWS CloudTrail Assessment

Correction from the original draft: the original report stated that “a CloudTrail trail was also configured during the assessment.” The evidence collected does not support this — the Trails console shows zero trails configured at the time of review. This section has been corrected accordingly.

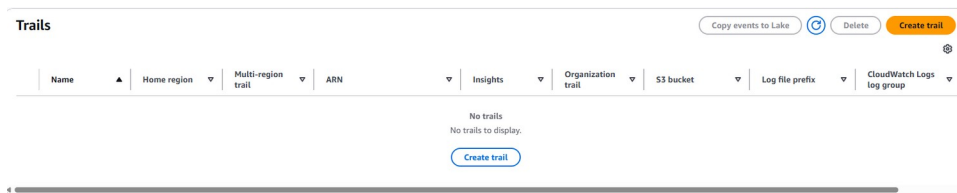


Figure 10 — CloudTrail → Trails: “No trails to display.” No dedicated trail has been created.

CloudTrail Event History (which AWS retains automatically for 90 days regardless of whether a trail is configured) was reviewed and showed management-plane API activity such as CreateBucket, PutBucketEncryption, SendSSHPublicKey, and security-group modifications — all attributed to the root user (see Section 3).

Finding: No Dedicated CloudTrail Trail Configured

Severity: Medium / High

Without a dedicated trail, event history is limited to the default 90-day window, is not delivered to an S3 bucket or CloudWatch Logs for long-term retention, and cannot be used for alerting, SIEM ingestion, or forensic investigation beyond that window.

Dedicated S3 object-level data-event logging (GetObject / PutObject / DeleteObject) is also not configured, since it depends on a trail existing.

Recommendation: Create a multi-region CloudTrail trail delivering logs to a dedicated, access-controlled S3 bucket (with its own logging/versioning enabled) and, for security-sensitive buckets, enable S3 data events to capture object-level operations.

6. IAM Access Analyzer

An External Access Analyzer was created in ap-south-1.

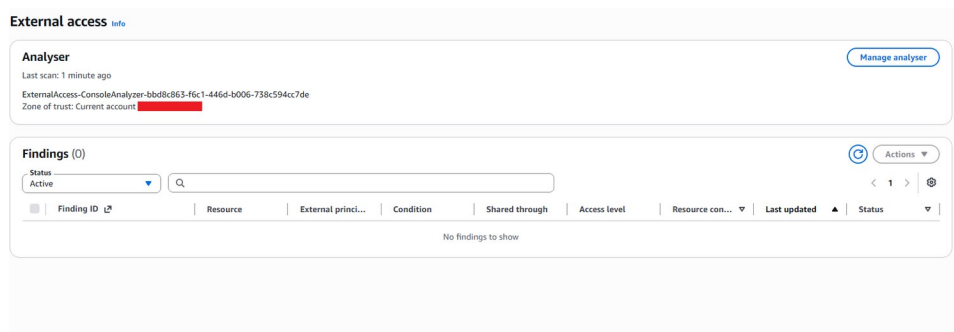


Figure 11 — IAM Access Analyzer: Active, 0 external-access findings.

Field	Result
Status	Active
Finding type	External access
Findings	0

This indicates that the analyzer did not identify resources with unintended external access based on the policies and resources it analyzed.

This is a strong result, although it does not mean every IAM permission is automatically secure — it reflects resource-based policy exposure, not identity-level over-permissioning.

7. Network Security Assessment

The environment contains multiple VPCs and subnets. The primary lab VPC is aws-security-lab-vpc.

Create VPC workflow

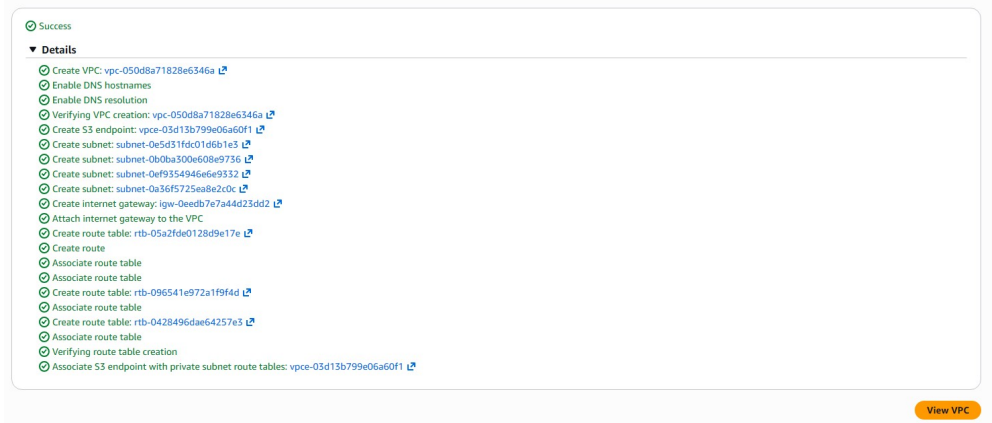


Figure 12 — VPC creation workflow: VPC, subnets, internet gateway, route tables, and S3 endpoint provisioned successfully.

7.1 Subnets

The environment contained 7 subnets, including public and private subnet configurations.

Name	Subnet ID	State	VPC	Block Public Access	IPv4 CIDR
aws-security-lab-subnet-private2-ap-so...	subnet-0a36f5725ea8e2c0c	Available	vpc-050d8a71828e6346a	Off	10.0.144.0/24
aws-security-lab-subnet-public1-ap-so...	subnet-0e5d31fd01d6b1e3	Available	vpc-050d8a71828e6346a	Off	10.0.0.0/24
-	subnet-0cec3d8e78169b3fe	Available	vpc-05a071fa009207a03	Off	172.31.0.0/24
-	subnet-0c95c4fc41f6a4ff6	Available	vpc-05a071fa009207a03	Off	172.31.32.0/24
aws-security-lab-subnet-private1-ap-so...	subnet-0ef9354946e6e9332	Available	vpc-050d8a71828e6346a	Off	10.0.128.0/24
aws-security-lab-subnet-public2-ap-so...	subnet-0b0ba300e608e9736	Available	vpc-050d8a71828e6346a	Off	10.0.16.0/24
-	subnet-063fd29181f69a079	Available	vpc-05a071fa009207a03	Off	172.31.16.0/24

Figure 13 — Subnets: 4 lab subnets (2 public, 2 private) plus 3 default-VPC subnets, all with Block Public Access off at the subnet level.

7.2 Public Route Table

Destination	Target	Status	Propagated	Route Origin
0.0.0.0/0	igw-0eedb7e7a44d23dd2	Active	No	Create Route
10.0.0.0/16	local	Active	No	Create Route Table

Figure 14 — Route table rtb-05a2fde0128d9e17e (aws-security-lab-rtb-public): 0.0.0.0/0 routed to the Internet Gateway.

Route table: rtb-05a2fde0128d9e17e (aws-security-lab-rtb-public). Important route: 0.0.0.0/0 → Internet Gateway. This confirms that the associated subnets have a route toward the Internet Gateway.

Assessment: Public subnet exposure exists by design. This is not automatically a vulnerability — the security impact depends on Security Group rules, Network ACLs, instance exposure, application configuration, and whether sensitive workloads are placed in those subnets.

7.3 EC2 Instance and Security Group

The original draft noted that “the security-group list alone does not provide enough evidence to classify individual inbound rules as vulnerable.” Additional evidence collected during the assessment does allow this to be classified — see below.

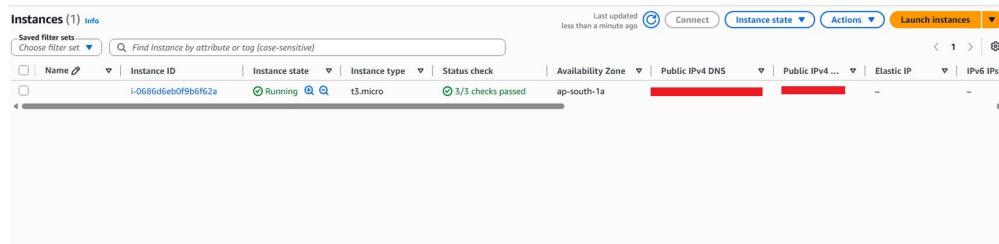


Figure 15 — EC2 instance i-0686d6eb0f9b6f62a (t3.micro) running in the public subnet with a public IPv4 address.

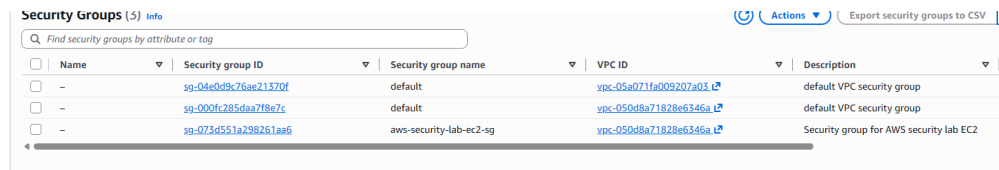


Figure 16 — Security Groups (3 total): default VPC groups plus aws-security-lab-ec2-sg.

A single t3.micro EC2 instance (i-0686d6eb0f9b6f62a) was deployed in the public subnet with a public IPv4 address, attached to security group sg-073d551a298261aa6 (aws-security-lab-ec2-sg).

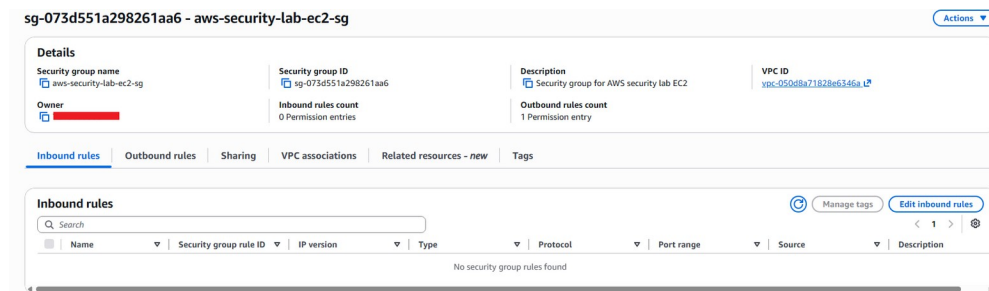


Figure 17 — Initial state: aws-security-lab-ec2-sg had 0 inbound permission entries.

At the start of testing, the security group had zero inbound rules — no ports, including SSH, were reachable from any source. An inbound rule was then deliberately added, scoped to a single administrator IPv4 address (/32) on TCP/22 for SSH access.

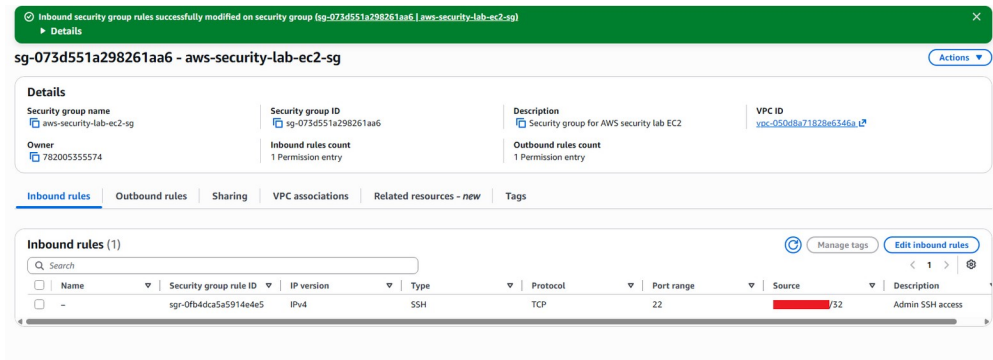


Figure 18 — Updated state: one inbound rule, SSH (TCP/22) scoped to a single /32 administrator address.

```

[ec2-user@ip-10-0-14-240 ~]$ sudo sshd -f | grep -E 'permitrootlogin|passwordauthentication|pubkeyauthentication|maxauthtries|permitemptypasswords'
maxauthtries 6
permitrootlogin without-password
pubkeyauthentication yes
passwordauthentication no
permitemptypasswords no

```

Figure 19 — sshd configuration on the instance: PasswordAuthentication no, PermitEmptyPasswords no, PubkeyAuthentication yes.

Positive finding: the EC2 security group was not left open to 0.0.0.0/0. SSH access is restricted to a single administrator IP address, and the instance's SSH daemon is configured to require key-based authentication with password authentication disabled. This is a well-configured host, and the earlier “not enough evidence” caveat in the original draft is superseded by this evidence.

8. AWS KMS

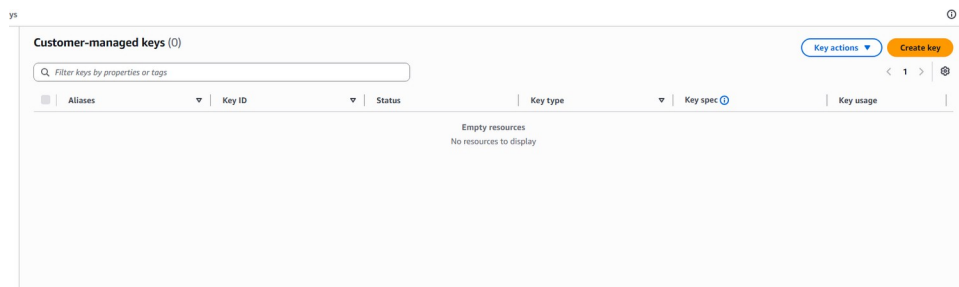


Figure 20 — Customer-managed KMS keys: 0.

Customer-managed keys: 0. No customer-managed KMS keys were configured. The S3 bucket uses SSE-S3 (Amazon S3-managed keys).

Assessment: Status Acceptable for the lab environment. SSE-S3 provides server-side encryption without requiring customer-managed KMS keys.

Recommendation: For environments requiring stronger organizational control over encryption keys, consider customer-managed KMS keys with defined key policies, rotation, least-privilege permissions, and CloudTrail monitoring.

9. Serverless, Database, and Container Services

No workloads were deployed in the following services during the assessment, so service-specific controls could not be evaluated:

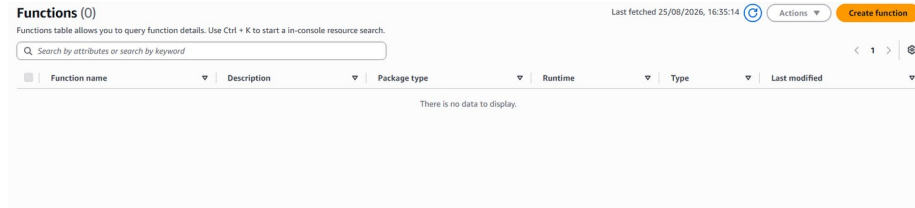


Figure 21 — Lambda: 0 functions configured.

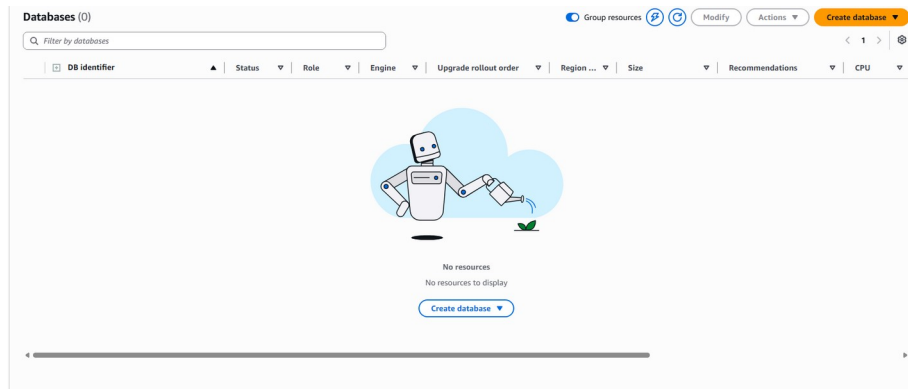


Figure 22 — RDS: 0 databases configured.

Service	Resources	Security Status
AWS Lambda	0 functions	N/A — No resources deployed
Amazon API Gateway	0 APIs	N/A — No APIs deployed
Amazon RDS	0 databases	N/A — No database resources deployed (public accessibility, encryption, backups, Multi-AZ, and security groups could not be assessed)
Amazon ECR	0 repositories	N/A — No container image repositories deployed
Amazon ECS	0 clusters	N/A — No ECS workloads deployed
AWS Secrets Manager	0 secrets	N/A — No secrets stored; no exposed credentials identified because no Secrets Manager resources exist

10. Logging and Monitoring (CloudWatch)

This section is new relative to the original draft. CloudWatch Observability was reviewed for alarms and telemetry ingestion.

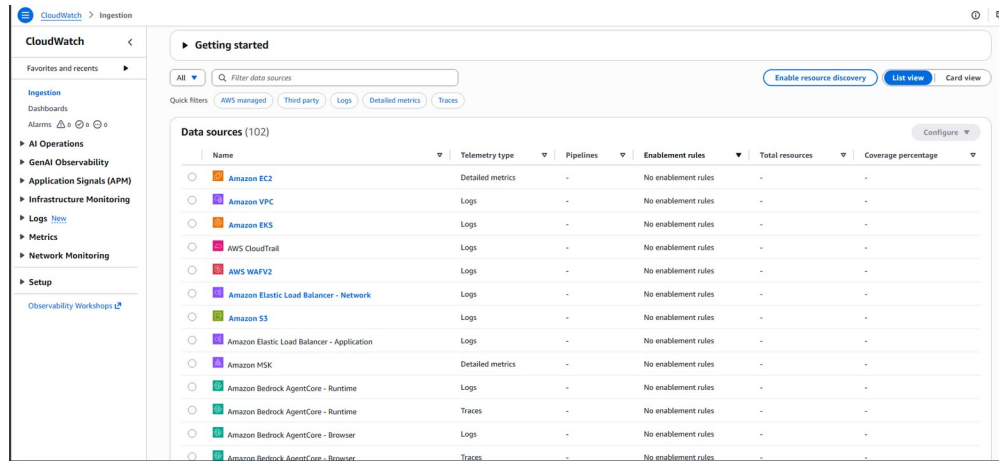


Figure 23 — CloudWatch Ingestion: 0 alarms configured; no enablement rules active for any of the 102 available AWS data sources (EC2, VPC, CloudTrail, S3, WAF, load balancers, etc.).

Finding: No CloudWatch Alarms or Monitoring Enablement Configured

Severity: Medium

CloudWatch shows zero alarms and no enablement rules across any of the available AWS telemetry sources. Combined with the absence of a CloudTrail trail (Section 5), the environment currently has no automated mechanism to detect or alert on suspicious activity, resource changes, or operational issues.

Recommendation: Enable CloudWatch alarms for security-relevant events (e.g. root account usage, IAM policy changes, security group changes) once a CloudTrail trail is in place, and consider enabling resource discovery/enablement rules for key services (EC2, VPC, S3).

11. Key Findings

ID	Finding	Severity	Status
F-00	Root user has no MFA enabled	High	Needs immediate remediation
F-01	No IAM users configured; all activity performed as root	Medium	Needs improvement
F-02	No dedicated CloudTrail trail configured (event history only)	High	Needs improvement — corrected finding
F-03	S3 Versioning disabled	Medium	Needs improvement
F-04	S3 Server Access Logging disabled	Medium	Needs improvement
F-05	S3 Object Lock disabled	Low	Consider enabling
F-06	CloudWatch: no alarms or monitoring enablement configured	Medium	Needs improvement — new finding
F-07	Public subnet with Internet Gateway route hosting an EC2 instance	Low	By design; mitigated by SG (see F-09)
F-08	No customer-managed	Low	Acceptable for lab use

ID	Finding	Severity	Status
	KMS keys (SSE-S3 in use)		
F-09	EC2 security group: no open inbound rules; SSH scoped to a single admin IP	Positive	Good
F-10	SSH daemon hardened (key-based auth only, no empty passwords)	Positive	Good
F-11	IAM Access Analyzer: 0 external-access findings	Positive	Good
F-12	S3 Block Public Access enabled	Positive	Good
F-13	S3 ACLs disabled / Bucket Owner Enforced	Positive	Good

12. Overall Risk Rating

MODERATE — trending toward HIGH on identity controls

The environment has good baseline controls against accidental public S3 exposure, external resource sharing, and unauthorized SSH access. The primary gaps are in account-level identity protection (root MFA, absence of named IAM users), audit-trail durability (no CloudTrail trail), data recovery (S3 versioning), and monitoring (CloudWatch alarms).

No Critical or High-severity finding related to direct external compromise was established from the evidence reviewed. The absence of root MFA is rated High because it represents a single point of failure for the entire account, not because external exploitation was demonstrated.

13. Recommended Remediation Priority

Priority 1 — Identity Protection

Enable MFA on the root user immediately. Create least-privilege IAM users or roles for routine administrative work and stop using the root user day-to-day.

Priority 2 — Audit Trail

Create a multi-region CloudTrail trail delivering to a dedicated, hardened S3 bucket. Enable S3 data events for sensitive buckets.

Priority 3 — Monitoring

Configure CloudWatch alarms for security-relevant events (root usage, IAM changes, security group changes) and enable resource discovery for key services.

Priority 4 — Data Recovery

Enable S3 Versioning for important data.

Priority 5 — Access Monitoring

Enable S3 server access logging or equivalent object-level monitoring.

Priority 6 — Data Immutability

Consider Object Lock for critical backups and security logs.

Priority 7 — Network Review

Periodically review inbound Security Group rules for any new resources deployed in public subnets, following the least-privilege pattern already used for the EC2 instance in this assessment.

14. Evidence Collected

Screenshots and CLI output were collected for the following areas. Representative evidence is embedded inline throughout this report; the full set (30 screenshots) is available in the accompanying evidence folder.

- S3: Block Public Access, Bucket Policy, Object Ownership / ACL, Encryption, Versioning, Logging, Event Notifications, Object Lock, Static Website Hosting
- CloudTrail: Event History, Trails
- IAM: Dashboard, IAM Users, IAM Access Analyzer
- VPC: Creation workflow, Subnets, Public Route Table, Security Groups
- EC2: Instance details, Security Group inbound rules (before/after), SSH connection, sshd hardening configuration, sudo configuration
- KMS, Lambda, RDS, ECR, ECS: resource inventories
- CloudWatch: data source ingestion and alarm configuration

15. Conclusion

The AWS environment demonstrates several appropriate cloud-security practices: blocking public S3 access, disabling S3 ACLs through Bucket Owner Enforced ownership, encrypting S3 data by default, deploying IAM Access Analyzer with no external-access findings, and running a tightly-scoped EC2 security group with hardened SSH access.

The assessment also surfaced gaps that were not fully captured in the original draft of this report: the root user has no MFA enabled and is being used for all operational activity in place of named IAM users, and no dedicated CloudTrail trail has been configured, meaning audit history is limited to the default 90-day event history.

The assessment did not identify a confirmed critical vulnerability arising from external exposure. However, the environment should not be considered fully hardened until root MFA is enabled, IAM users replace root for daily operations, a durable CloudTrail trail and CloudWatch monitoring are in place, and the remaining S3 data-protection controls (versioning, logging, Object Lock) are enabled.